

From Enumeration to Vulnerability Analysis

Going from “I found a service” to “I have enough evidence to call something a vulnerability or decide that I don’t”

Retrieval + cleanup

SMB: What is the difference between authentication, share visibility, and authorization?

OUTLOUD!

DNS: What information does an SRV record reveal?

Reveals where a particular network service is located and how to reach it

LDAP: Explain: DC=kevinlab,DC=local and what a Base DN is.

OUTLOUD!

Why was Alice being able to enumerate domain users/groups through LDAP not automatically a vulnerability?

The permissions here can be normal; need to determine whether this access violates the intended security model

Theory: What is a Vulnerability, Really?

Exposure

Something is reachable. Example: 445/tcp open. This tells us SMB appears accessible. That's exposure. It is not necessarily bad.

Weakness

A weakness is something about the implementation/configuration that reduces security.

Examples: Legacy protocol enabled, weak authentication, unnecessary anonymous access, overly broad permissions, missing security control

Vulnerability

A vulnerability is a weakness that can actually be exploited or abused to negatively affect security.

Conceptually: service exists -> configuration/version investigated -> security weakness identified -> required conditions validated -> potential security impact -> vulnerability

Finding

In professional assessment work, I will eventually write a finding. A finding is the documented security issue you're reporting. It should answer: What did I observe, What evidence proves it, Why is it dangerous, Under what conditions can it be abused, What is the impact, How should it be fixed

Sometimes an assessment produces: No finding.

CVE

CVE-YYYY-NNNN

CVE stands for Common Vulnerabilities and Exposures

It provides standardized identifiers for publicly known vulnerabilities. Finding software whose name appears beside a CVE does not prove your target has that CVE. Need to check things such as: Affected product, Affected version, Patch state, Configuration, Required Conditions, Architecture

CVSS

Common Vulnerability Scoring System

Provides a standardized way of describing vulnerability severity. I can encounter scores such as: 3.1, 6.5, 9.8 or broadly: Low, Medium, High, Critical

Severity DNE organizational priority....a technical critical vulnerability on an isolated, irrelevant machine might have different practical priority than a somewhat lower-scored issue on the company's Domain Controller

False positives

A scanner might say: "Possible vulnerability detected."

When you investigate: Wrong software version, already patched, required feature disabled, mitigation present, scanner inference incorrect. So the target isn't actually vulnerable; it's a false positive.

Methodology to burn into my head

When I discover a service:

1. Identify what exists
2. Gather version/configuration evidence
3. Identify candidate weaknesses
4. Research authoritative information
5. Determine required conditions
6. Compare those conditions against the target
7. Validate safely
8. Assess impact
9. Finding OR no finding
10. Remediate and retest when appropriate

Guided Practical: Externally Validate SMB Hardening

Target: SRV-DC01

Question: Which SMB protocol generations does the server support and is SMB signing required?

External Assessment

Command: **nmap -Pn -p 445 **

**--script smb-protocols,smb2-security-mode **
192.168.1.236

Smb-protocols: attempts to identify which SMB dialects/protocol generations are supported (will smb1 appear?)

Smb2-security-mode: retrieves smb2-family security-mode information, including signing behavior

```
(nigist@kaliN)-[~]
$ nmap -Pn -p 445 \
> --script smb-protocols,smb2-security-mode \
> 192.168.1.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-28 11:12 EDT
Nmap scan report for 192.168.1.236
Host is up (0.0023s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled and required
| smb-protocols:
|   dialects:
|     2:0:2
|     2:1:0
|     3:0:0
|     3:0:2
|_    3:1:1

Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds
```

SMB versions supported are shown: 2.0.2, 2.1.0, 3.0.0, 3.0.2, 3.1.1

Corroborate from the server side

Command: **Get-SmbServerConfiguration | Select-Object EnableSMB1Protocol, EnableSMB2Protocol, EnableSecuritySignature, RequireSecuritySignature**

```
PS C:\Users\Administrator> Get-SmbServerConfiguration | Select-Object EnableSMB1Protocol, EnableSMB2Protocol, EnableSecuritySignature, RequireSecuritySignature

EnableSMB1Protocol EnableSMB2Protocol EnableSecuritySignature RequireSecuritySignature
-----
False              True              True              True
```

First Vulnerability Decision

Observation: TCP/445 exposes SMB.

Evidence: See screenshot from practical.

Security expectation: Legacy SMB should not be required. SMB signing should be appropriately enforced.

Observed state: Practical screenshot.

Finding: No.

Reasoning: The commands reveal that Legacy SMB is not required. SMB signing is enabled and required.